



भारतीय प्रौद्योगिकी संस्थान हैदराबाद
Indian Institute of Technology Hyderabad

CS6903: Network Security

(Module 3: Public Key Infrastructure)

Saurabh Kumar
CSE Department, IIT Hyderabad

Acknowledgement

- ❑ Instructors from previous course floating
 - Prof. Bheemarjuna Reddy Tamma, Prof. Kotaro Kataoka, Prof. Antony Franklin
- ❑ Professors from other Universities/Insitutes
 - Sandeep K. Shukla, Stefan Savage, Dan Boneh, Kirill Levchenko, Alex Gantman, Deian Stefan, Nadia Heninger, Alex Dent, Vitaly Shamtikov, Robert Turner
- ❑ Other internet sources

Integrity of Public Keys

□ **Motivation:** Trudy plays pizza prank on Bob

- Trudy creates e-mail order: Dear Pizza Store, Please deliver to me four pepperoni pizzas. Thank you, Bob
- Trudy signs order with her private key K_T^-
- Trudy sends order to Pizza Store
- Trudy sends to Pizza Store her public key K_T^+ , but says it's Bob's public key
- Pizza Store verifies signature; then delivers four pepperoni pizzas to Bob
- Bob doesn't even like pepperoni

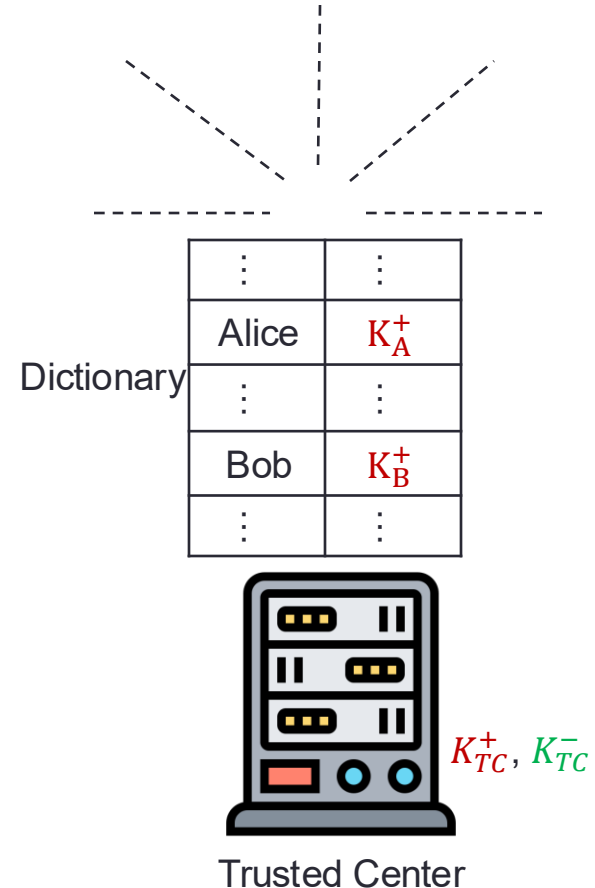


How to verify integrity of Public Keys?

Trusted Third Party Approach

□ Trusted Center (TC)

- Verifies identities of user before registration
- Stores list of public keys for registered users
- Has own key pair K_{TC}^+ , K_{TC}^-
- Will provide public keys upon request, signed by the trusted center with K_{TC}^-
- All users know the public key K_{TC}^+ of trusted center



Trusted Center

- Alice sends request for Bob's public key K_B^+ to center
 - Includes time stamp to prevent replay
- Trusted Center sends Bob's key K_B^+ to Alice
 - Include timestamp signed with TC's private key K_{TC}^-
 - Alice verifies with TC's public key K_{TC}^+

⋮	⋮
Alice	K_A^+
⋮	⋮
Bob	K_B^+
⋮	⋮

Dictionary

Alice



Needs Bob's key, T : Timestamp



Bob's public key K_B^+ , T : Timestamp
Signed by center's private key K_{TC}^-



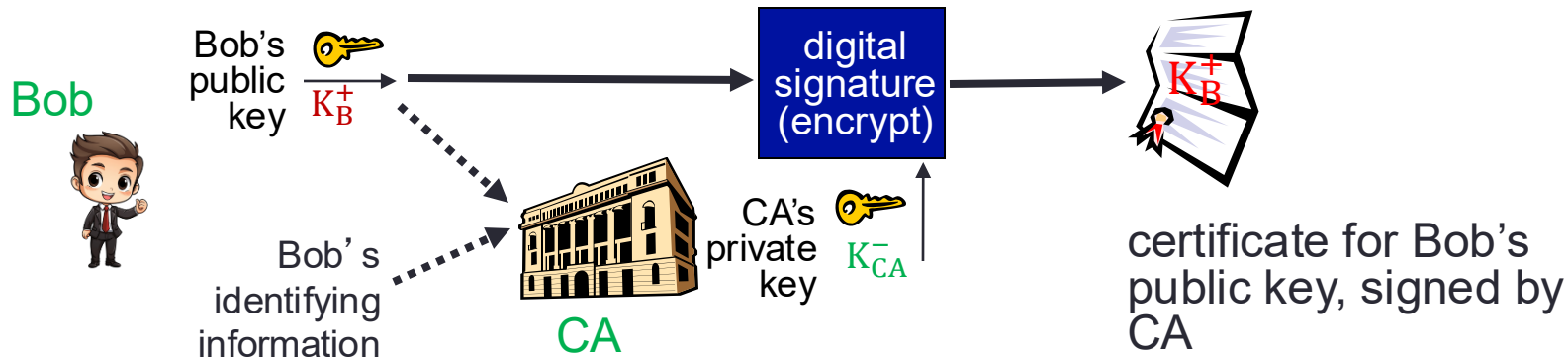
K_{TC}^+ , K_{TC}^-
Trusted Center

Public Key Certification Authority (CA)

- ❑ Problem: Trusted Center approach is very inefficient
 - Might need to handle millions of requests simultaneously
- ❑ Solution:
 - Public key certificates a.k.a Digital Certificates
 - Issued by Certification Authority
 - Trusted third party (Verisign, Equifax, GoDady, DigiCert, etc.)
 - Well known public key
- ❑ Certificate contains user's public key, signed by with CA's private key

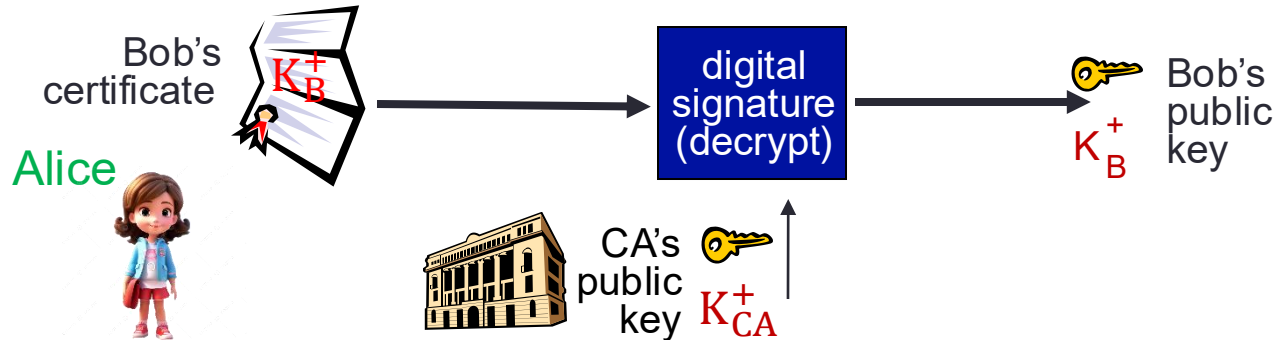
Public Key Certification Authority (CA)

- ❑ **CA**: binds public key to particular entity E (person, webserver, router, etc.)
- ❑ Entity E registers its public key K_E^+ with **CA** and provides “proof of identity” to **CA**
 - CA creates certificate binding identity E to E’s public key K_E^+
 - Certificate containing E’s public key K_E^+ digitally signed by **CA**: saying “this is E’s public key K_E^+ ”



Public Key Certification Authority (CA)

- When Alice wants Bob's public key:
 - Gets Bob's certificate (Bob or elsewhere)
 - Apply CA's public key K_{CA}^+ to Bob's certificate,
 - Get Bob's public key K_B^+



Applications

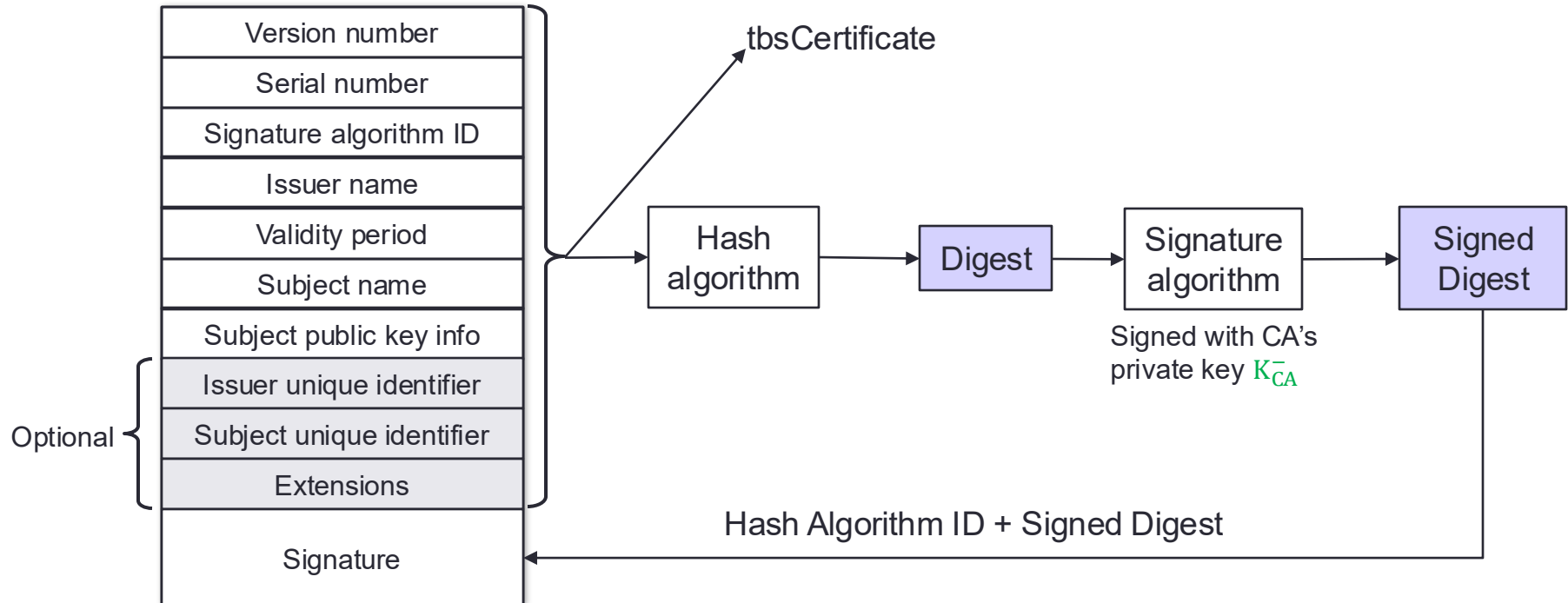
- ❑ TLS certificate: for authenticated and encrypted browsing
- ❑ S/MIME certificates: for signing and encrypting emails
- ❑ Code signing certificates
- ❑ Document signing certificates
- ❑ Client authentication certificates
- ❑ Government issues electronic IDs

Digital Certificates (DCs)

- ❑ DC is a signed data structure that binds a public key to an entity.
- ❑ DCs (also called X.509 certificates) are described using [Abstract Syntax Notation One \(ASN.1\)](#)
 - ASN.1 is a standard used to exchange information between systems independently of their encoding techniques
- ❑ DCs are defined using ASN.1 and encoded using Privacy Enhanced Mail (PEM, Base64-ASCII) or Distinguished Encoding Rules (DER, binary)
 - Stored with extensions like .crt, .cer, .der, .pem
- ❑ The signature field in DC contains a digital signature computed upon the ASN.1 DER encoded tbsCertificate structure in the certificate
 - tbs: **tobesigned**

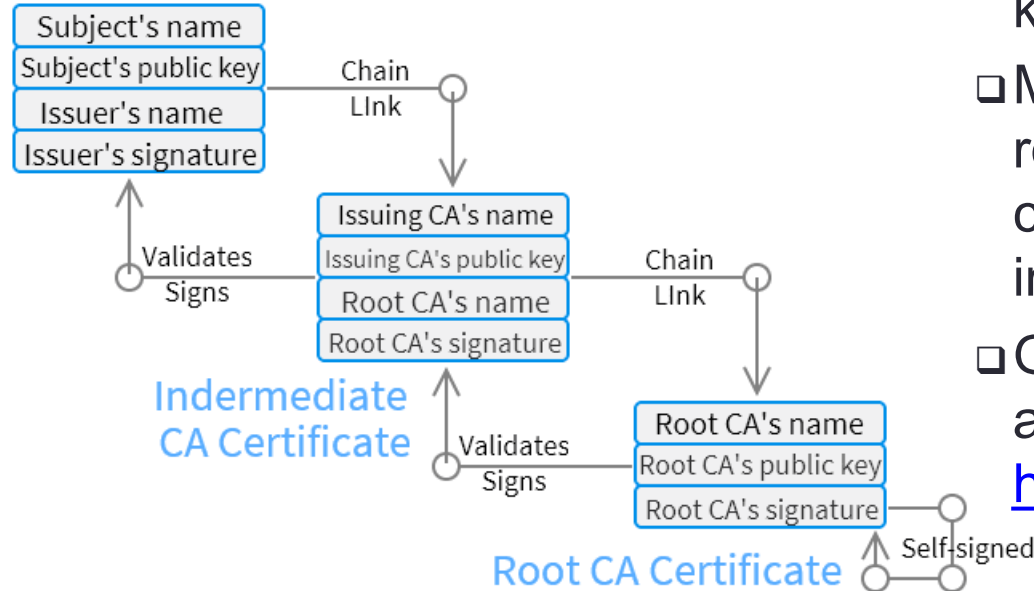
X.509 Standard

- ❑ X.509 Standard provides common format for all certificates
 - Makes verification much simpler



The Chain of Trust

End-entity Certificate

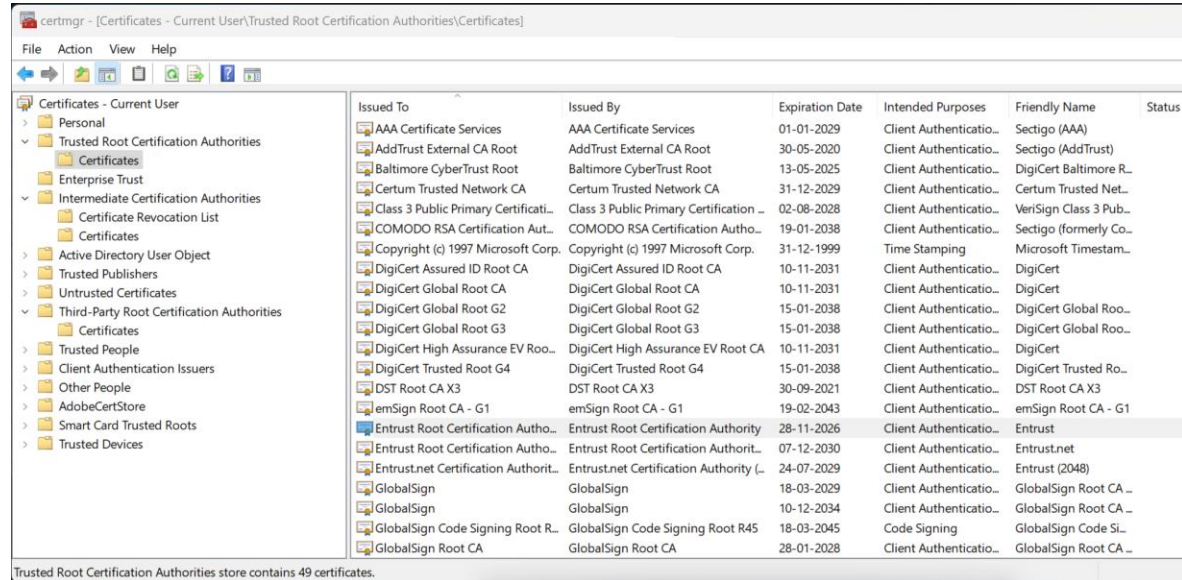


- ❑ CAs are trusted signers of public keys in web PKI
- ❑ Many browsers and OSes have root stores with pre-installed certificates of root and intermediate CAs
- ❑ Google operates several root and intermediate CAs: <https://pki.goog/>

CAs and Root Stores in Windows 11

❑ Browser/OSes are pre-loaded with certs of several root and intermediate CAs

- DigiCert
- GlobalSign
- Entrust



Issued To	Issued By	Expiration Date	Intended Purposes	Friendly Name	Status
AAA Certificate Services	AAA Certificate Services	01-01-2029	Client Authentication...	Sectigo (AAA)	
AddTrust External CA Root	AddTrust External CA Root	30-05-2020	Client Authentication...	Sectigo (AddTrust)	
Baltimore CyberTrust Root	Baltimore CyberTrust Root	13-05-2025	Client Authentication...	DigiCert Baltimore R...	
Certum Trusted Network CA	Certum Trusted Network CA	31-12-2029	Client Authentication...	Certum Trusted Net...	
Class 3 Public Primary Certificati...	Class 3 Public Primary Certification ...	02-08-2028	Client Authentication...	VeriSign Class 3 Pub...	
COMODO RSA Certification Aut...	COMODO RSA Certification Autho...	19-01-2038	Client Authentication...	Sectigo (formerly Co...	
Copyright (c) 1997 Microsoft Corp.	Copyright (c) 1997 Microsoft Corp.	31-12-1999	Time Stamping	Microsoft Timestam...	
DigiCert Assured ID Root CA	DigiCert Assured ID Root CA	10-11-2031	Client Authentication...	DigiCert	
DigiCert Global Root CA	DigiCert Global Root CA	10-11-2031	Client Authentication...	DigiCert	
DigiCert Global Root G2	DigiCert Global Root G2	15-01-2038	Client Authentication...	DigiCert Global Roo...	
DigiCert Global Root G3	DigiCert Global Root G3	15-01-2038	Client Authentication...	DigiCert Global Roo...	
DigiCert High Assurance EV Roo...	DigiCert High Assurance EV Root CA	10-11-2031	Client Authentication...	DigiCert	
DigiCert Trusted Root G4	DigiCert Trusted Root G4	15-01-2038	Client Authentication...	DigiCert Trusted Ro...	
DST Root CA X3	DST Root CA X3	30-09-2021	Client Authentication...	DST Root CA X3	
emSign Root CA - G1	emSign Root CA - G1	19-02-2043	Client Authentication...	emSign Root CA - G1	
Entrust Root Certification Autho...	Entrust Root Certification Authority	28-11-2026	Client Authentication...	Entrust	
Entrust Root Certification Autho...	Entrust Root Certification Authority...	07-12-2030	Client Authentication...	Entrust.net	
Entrust.net Certification Authorit...	Entrust.net Certification Authority (...)	24-07-2029	Client Authentication...	Entrust (2048)	
GlobalSign	GlobalSign	18-03-2029	Client Authentication...	GlobalSign Root CA ...	
GlobalSign	GlobalSign	10-12-2034	Client Authentication...	GlobalSign Root CA ...	
GlobalSign Code Signing Root R...	GlobalSign Code Signing Root R45	18-03-2045	Code Signing	GlobalSign Code Si...	
GlobalSign Root CA	GlobalSign Root CA	28-01-2028	Client Authentication...	GlobalSign Root CA ...	

Trusted Root Certification Authorities store contains 49 certificates.

TLS/SSL Certificate Types

Subjects Common Name (CN) and SubjectAlternativeName (SAN) can be:

- ❑ Single domain cert (explicit name) e.g., iith.ac.in or cse.iith.ac.in
- ❑ Wildcard cert, e.g. *.iith.ac.in or cse*.iith.ac.in
 - Matching rules: “*” must occur in leftmost component, does not match “.”
 - Example: *.a.com matches x.a.com but not y.x.a.com
- ❑ Multi-Domain (SAN or UCC: Unified Communications Certificate) cert allows 250-500 unique domain in a single cert
 - For compatibility, primary FQDN (fully qualified domain name) in CN, and the full list of FQDNs in SAN E.g., <https://www.nsa.gov/>
- ❑ Multi-Domain Wildcard Certificates
 - FQDNs/wildcard domains in SAN list E.g., [X.509 -Wikipedia](#)

TLS Certificate Validation Levels

Based on thoroughness in validation process by the CA:

- ❑ DV (Domain validation) Cert

- Prove that you own the domain

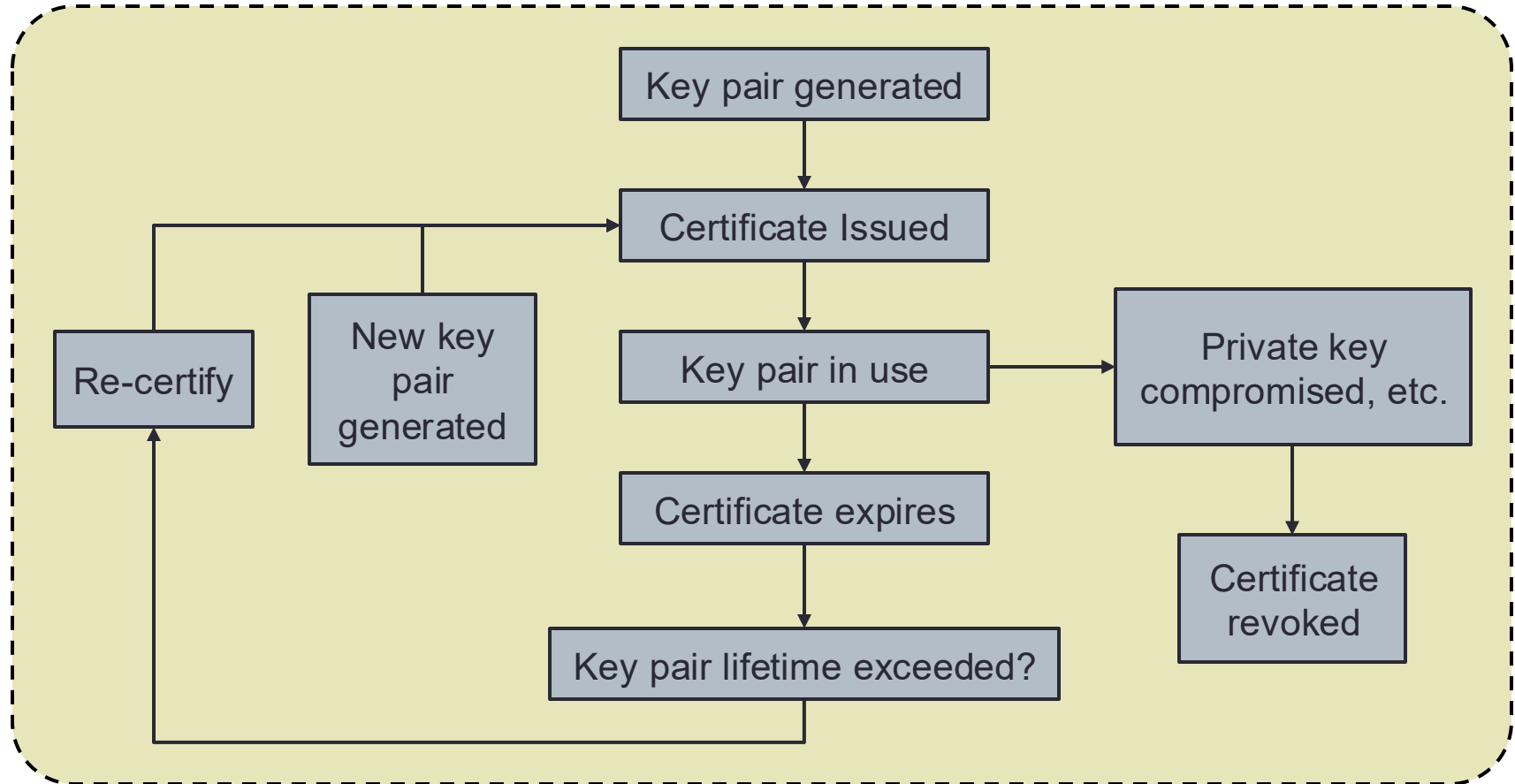
- ❑ OV (Organization Validation) Cert

- A manual vetting process by CA, so expensive
- Enterprises

- ❑ EV (Extended Validation Cert)

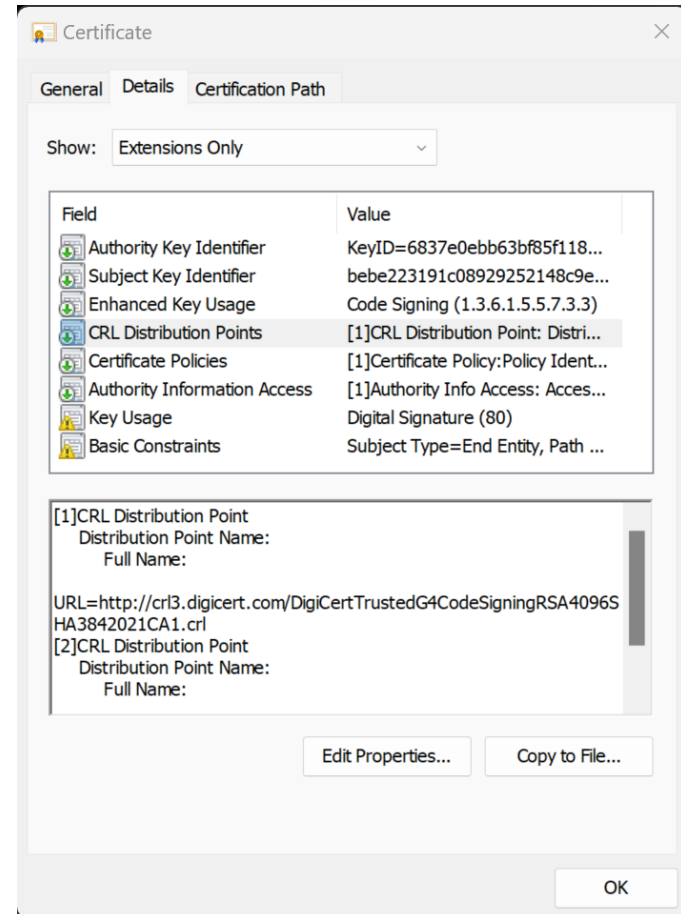
- Full background check, very expensive
- banks/e-commerce

Certificate Life Cycle



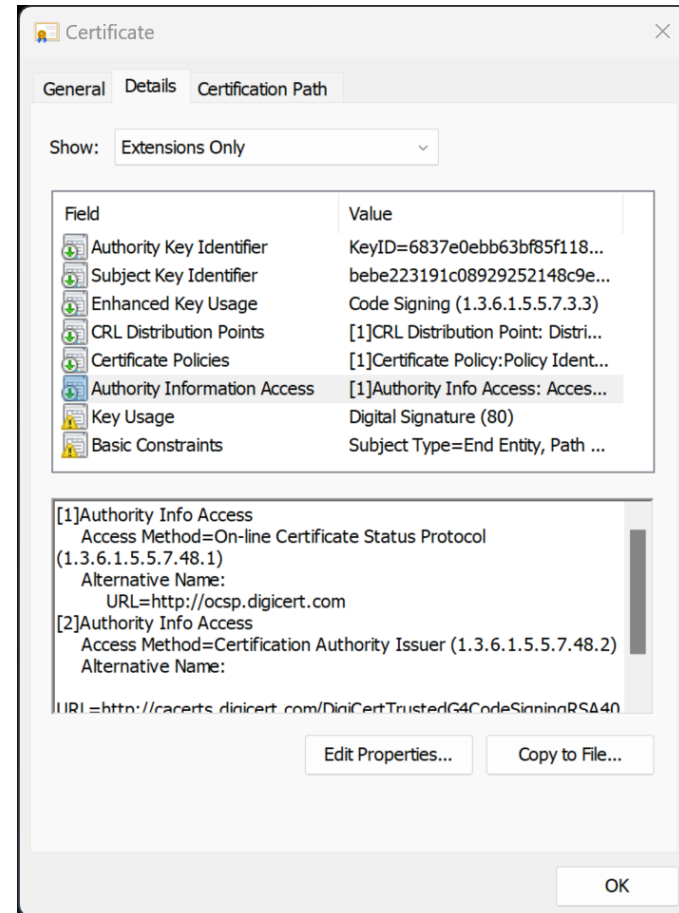
Certificate Revocation

- ❑ Two mechanisms: CRL and OCSP
- ❑ Certificate Revocation List (CRL)
 - CA periodically publishes/updates CRLs which are time-stamped & signed
 - Each revoked certificate is identified in a CRL by its serial number
 - CRL might be distributed by posting at known URL or from CA's own X.509 directory entry, specified in the certificate
 - Browsers have to download a large amount of cert revocation info from the updated CRLs
 - What if CRL server is down?



Certificate Revocation

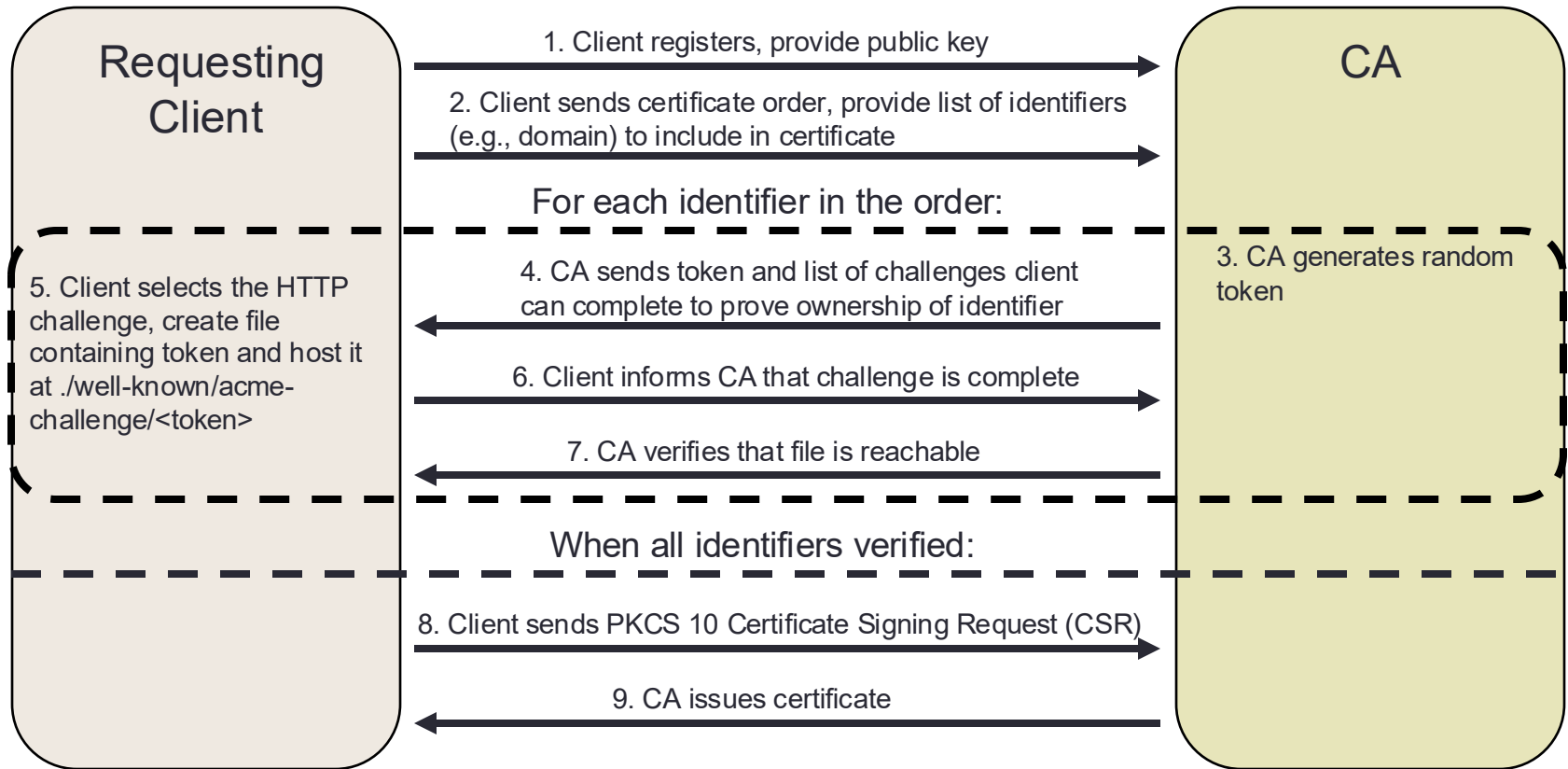
- ❑ OCSP (Online Certificate Status Protocol)
 - No need of downloading & searching
- ❑ Browser (Alice) queries CA's OCSP server about status of webserver's (Bob) cert before trusting it
- ❑ OCSP Stapling
 - Bob queries OCSP servers & caches it
 - Bob includes recent OCSP status when performing TLS handshake with Alice
 - Avoids delay due to OCSP TLS negotiation with CA by piggybacking in Bob's TLS pipe
 - Addresses privacy issues with CA



Let's Encrypt and ACME Protocol

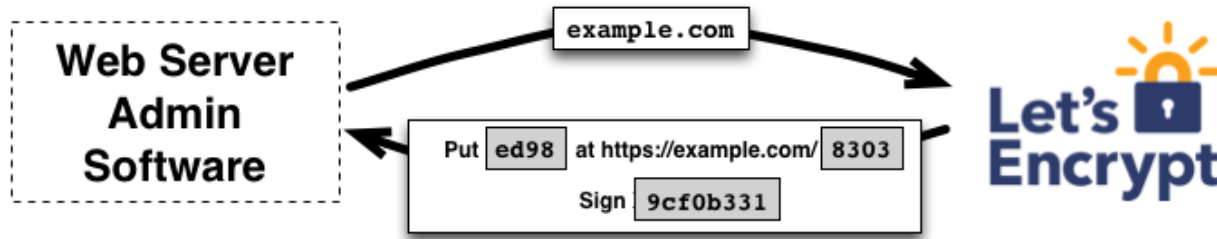
- ❑ Let's Encrypt is a free, automated, and open CA from non-profit ISRG (Internet Security Research Group)
- ❑ Certificates need to be requested, installed, and maintained frequently, which is time-consuming & boring!
- ❑ So, Let's Encrypt uses an open protocol to automate the deployment of certificates: [ACME](#) (Automated Certificate Management Environment)
 - ACME implements automated interactions between CA and web servers, removing all the burden of getting and maintaining certificates
- ❑ Many tools based on ACME
 - Certbot: client to fetch, install, renew certificates
 - Caddy: Open source, webserver

ACME Protocol



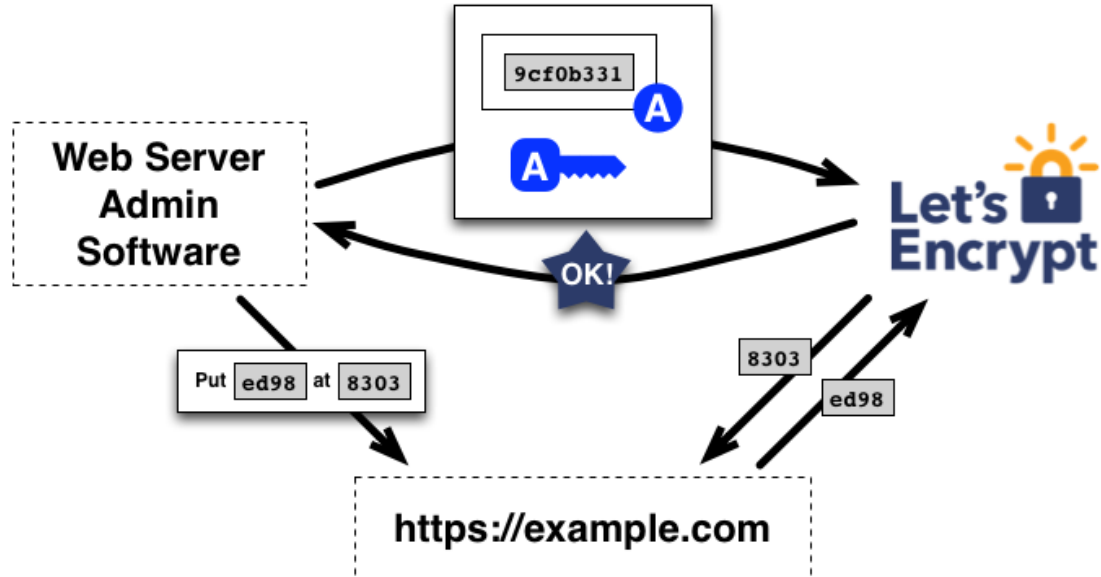
ACME Protocol

- ❑ ACME automates requests, installation & maintenance of TLS certs
- ❑ Agent s/w on webserver has to solve challenges posed by LE CA to prove ownership of the domain name
 - HTTP-01 challenge: a specified file in a specified location on a webserver accessible on port 80 and sign a token
 - DNS-01 challenge: set up a specified DNS record



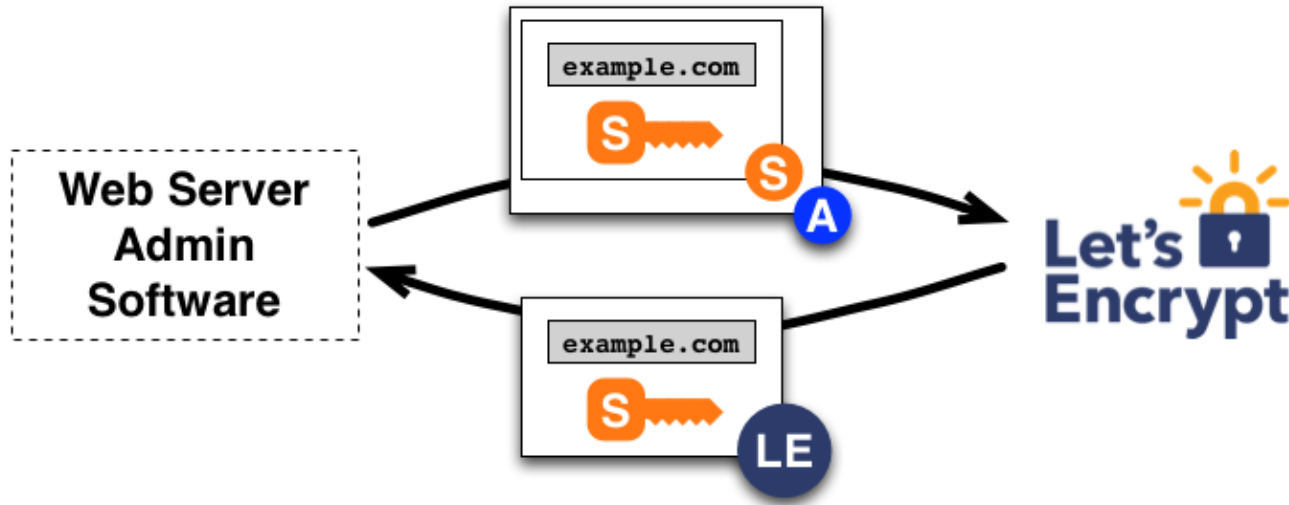
ACME: Domain Validation

- ❑ Agent identified by the public key (K_A^+) is authorized to do certificate management for example.com
 - The key pair, the agent used, is an “authorized key pair” for example.com



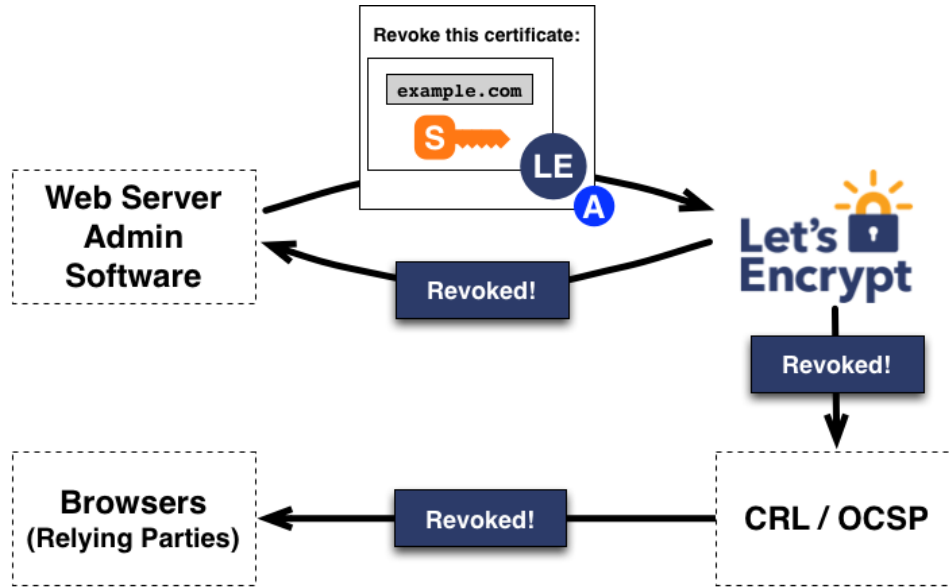
ACME: Cert Issuance

- Agent generates CSR signed with private key (K_S^-) of webserver which is in turn signed with private key of Agent (K_A^-)



ACME: Certificate Revocation

- Agent generates certificate revocation request signed with private key of Agent (K_A^-)



CCA: Root CA of India

<https://cca.gov.in/CAServicesOverview.html>



Controller of Certifying Authorities
Ministry of Electronics & Information Technology
Government of India

[Home](#) [About CCA](#) [Services](#) [FAQ](#)

[Contact us](#)



Follow us :



[PKI Framework](#) [Root CA of India](#) [Licensed CAs](#) [Root Certificate](#) [CA Certificates](#) [eSign](#) [Guidelines](#)

Home » CA Services Overview

1. Safescrypt
2. IDRBT
3. (n)Code Solutions
4. e-Mudhra
5. CDAC
6. Capricorn
7. Protean (NSDL e-Gov)
8. Vsign (Verasys)
9. Indian Air Force
10. CSC
11. RISL (RajComp)
12. Indian Army
13. IDSign
14. CDSL Ventures
15. Panta Sign
16. xtra Trust
17. Indian Navy
18. ProDigiSign
19. SignX
20. JPSSL
21. Care 4 Sign
22. IGCAR
23. Speed Sign

[CA Services Overview](#)

[CA Services to Public](#)



OVERVIEW OF SERVICES AVAILABLE WITH LICENSED CAs

	Licensed CAs	Class 1 – 3 DSCs	SSL*	Time Stamping
1.	Safescrypt	✓		✓
2.	(n) (Code Solutions	✓		✓
3.	e-Mudhra	✓	✓	✓
4.	Capricorn	✓		✓
5.	Vsign (Verasys)	✓		✓
6.	RISL (RajComp)	✓	✓	✓
7.	IDSign	✓		✓
8.	Pantesign	✓		✓
9.	Xtra Trust	✓		✓
10.	ProDigiSign	✓		✓
11.	SignX	✓		✓
12.	Care 4 Sign	✓		✓
13.	CDAC			
14.	Protean(NSDL e-GOV)			✓
15.	CSC			✓/CSL
16.	CDSL Ventures			✓/CSL
17.	RPSL			✓
18.	IDRBT	✓/Basis	✓/Basis	✓/Basis
19.	Indian Air Force	✓/IAF	✓/IAF	✓/IAF
20.	Indian Army	✓/Army	✓/Army	✓/Army
21.	Indian Navy	✓/Navy	✓/Navy	✓/Navy
22.	IGCAR	✓/IGCAR	✓/IGCAR	✓/IGCAR

* The Root CA Certificate of India is listed only in Microsoft products (Including IE)

CLOSED CAs

Licensed CAs	Class 1 – 3 DSCs	SSL and Code Signing Certificates
MTNL	NA	NA
iCERT	NA	NA
TCS	NA	NA
NIC	NA	NA

Summary

- ❑ Public key crypto is a powerful tool
 - Underlies https, ssh, virtually all software updates, etc.
 - But doesn't solve the key distribution problem
- ❑ Certificate authorities (CA) occupy a very key (and trusted) role
 - 3rd party attestation of identity or access
 - Public, private and open CAs
 - Let's Encrypt made them affordable to all
 - Other uses of certificates: digital signs, code signing, time stamping, etc
 - Ongoing efforts to police CAs